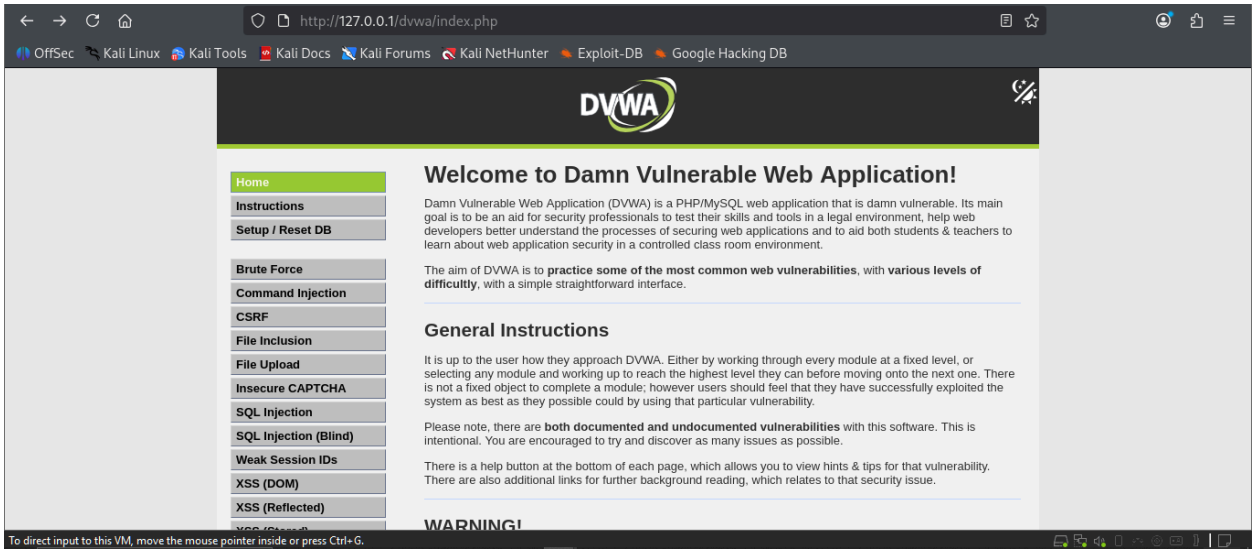
INTRODUCTION

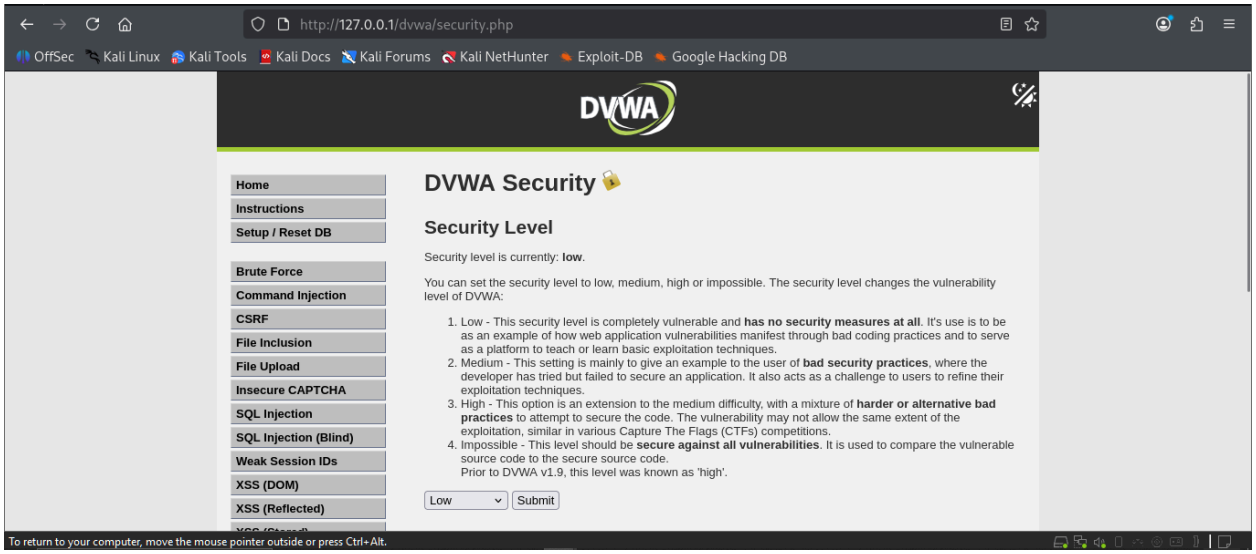
Exploit an SQL injection vulnerability on DVWA

SQL injection is a common attack used by hackers to exploit SQL database-driven web applications. This type of attack involves inserting malicious SQL code or statements into an input field or URL with the goal of revealing or manipulating the database contents, causing repudiation system issues, or spoofing identities. In other hands,SQL injection is a code injection technique used to exploit security vulnerabilities in the database layer of an application. These vulnerabilities could allow an attacker to execute malicious SQL commands and compromise the security of the database.
In this part we will exploit a SQL vulnerability on the DVWA.

Step 1: Prepare DVWA for SQL Injection Exploit.

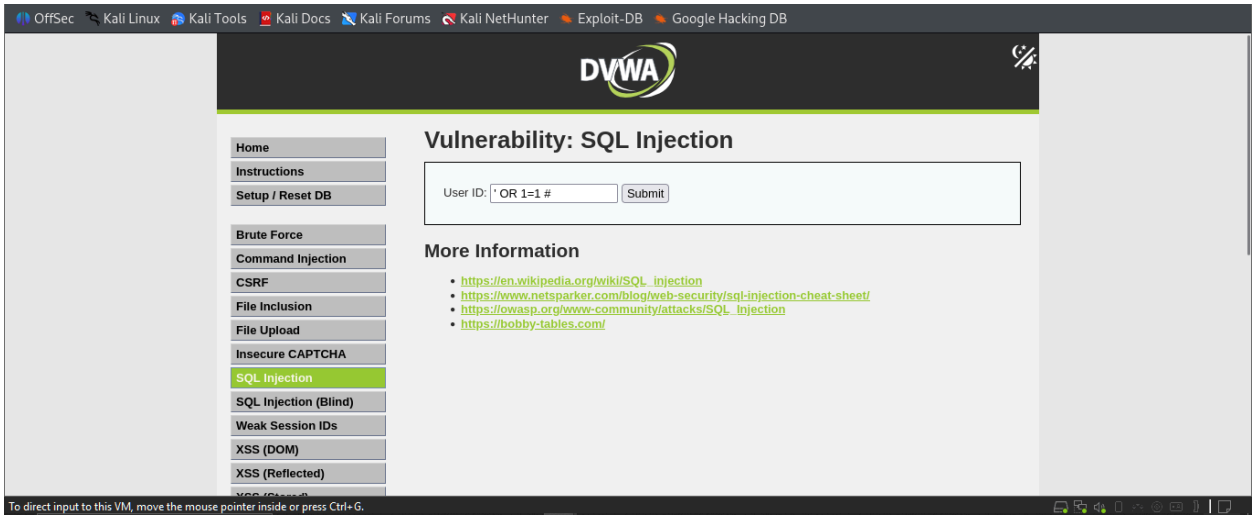
- Open your browser and navigate to the DVWA default localhost at http://127.0.0.1/dvwa but before you do that make sure DVWA file is up and running
- Enter the default credentials: admin / password.
- Set DVWA to Low Security by clicking DVWA Security in the left panel
- Change the security level to Low and click Submit.
- See below the screenshots of DVWA homepage and the DVWA security level

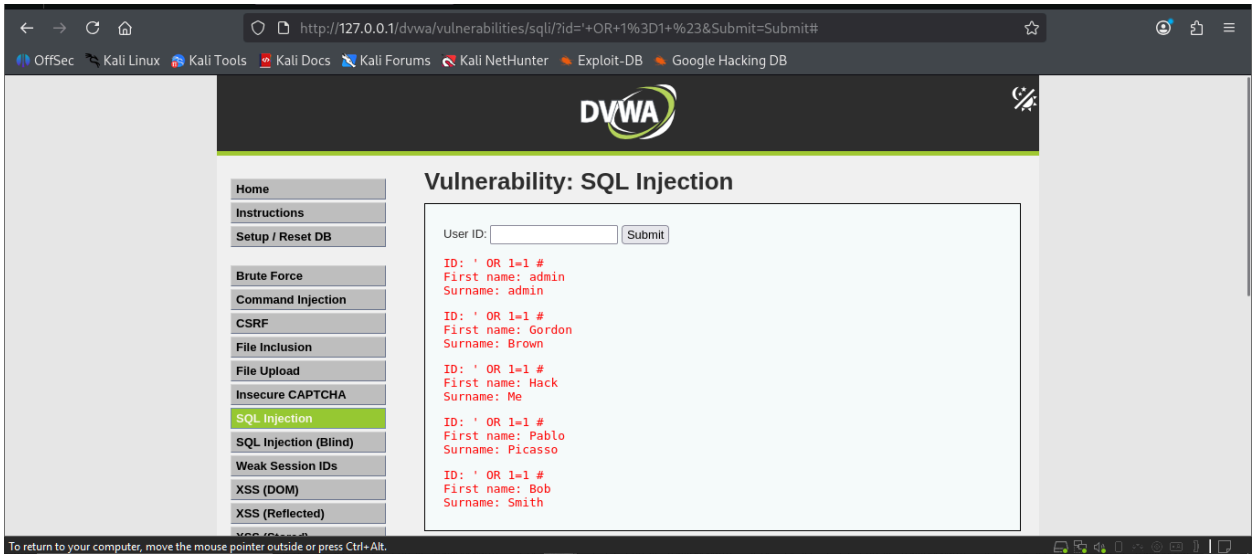




Step 2: Check DVWA to see if a SQL Injection Vulnerability is Present.

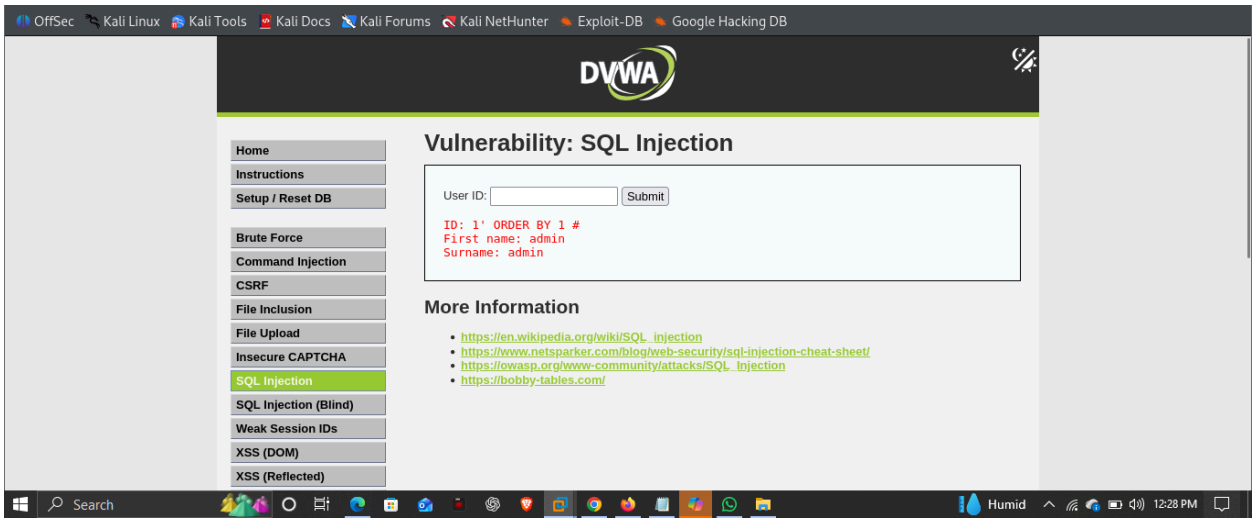
- Click SQL Injection in the left panel.
- In the User ID: field type ' OR 1=1 # and click Submit.
- You should receive the output shown below. The output confirms that there is a vulnerability present that permits execution of SQL statements that are entered directly into input fields.
- You have entered an “always true” expression that was executed by the database server. The result is that all entries in the ID field of the database were returned
- See below the screenshots of user ID: field type ‘OR 1=1# and the output



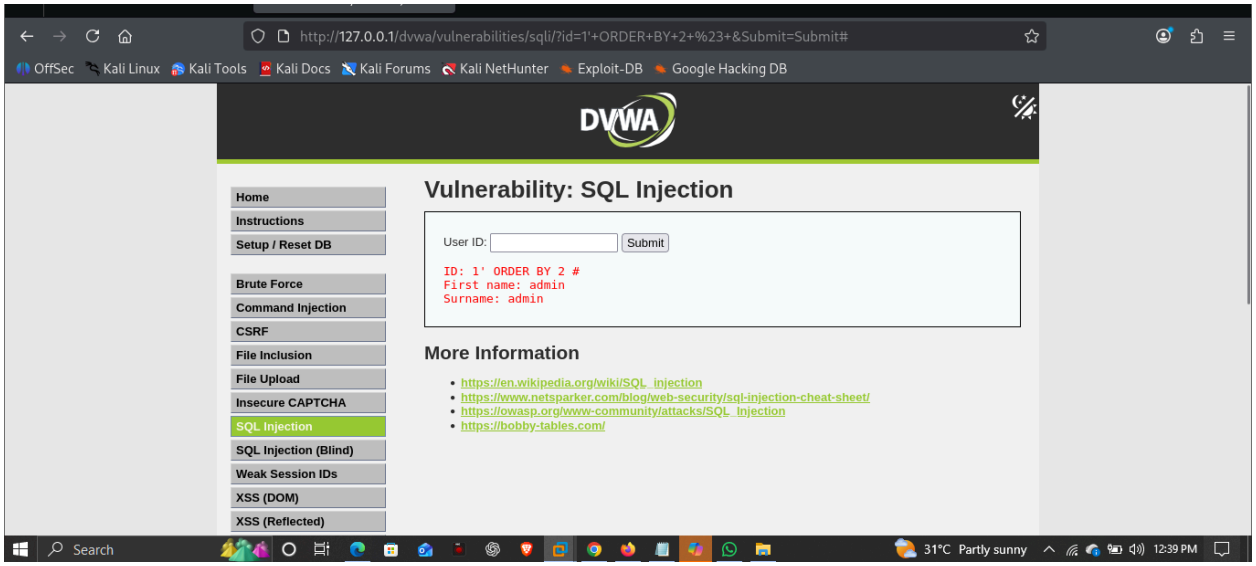


Step 3: Check for the number of Fields in the Query

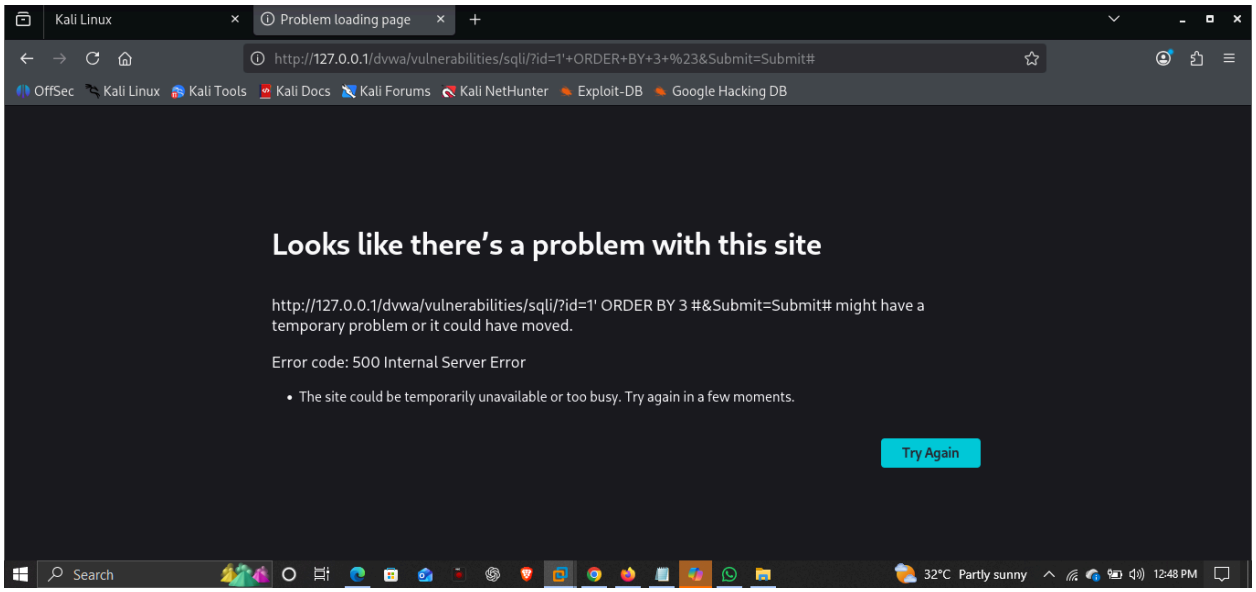
- In the User ID: field type 1' ORDER BY 1 # and click Submit.
- You should receive the following output, see screenshot below



- In the User ID: field type 1' ORDER BY 2 # and click Submit.
- You should receive the following output, see screenshot below

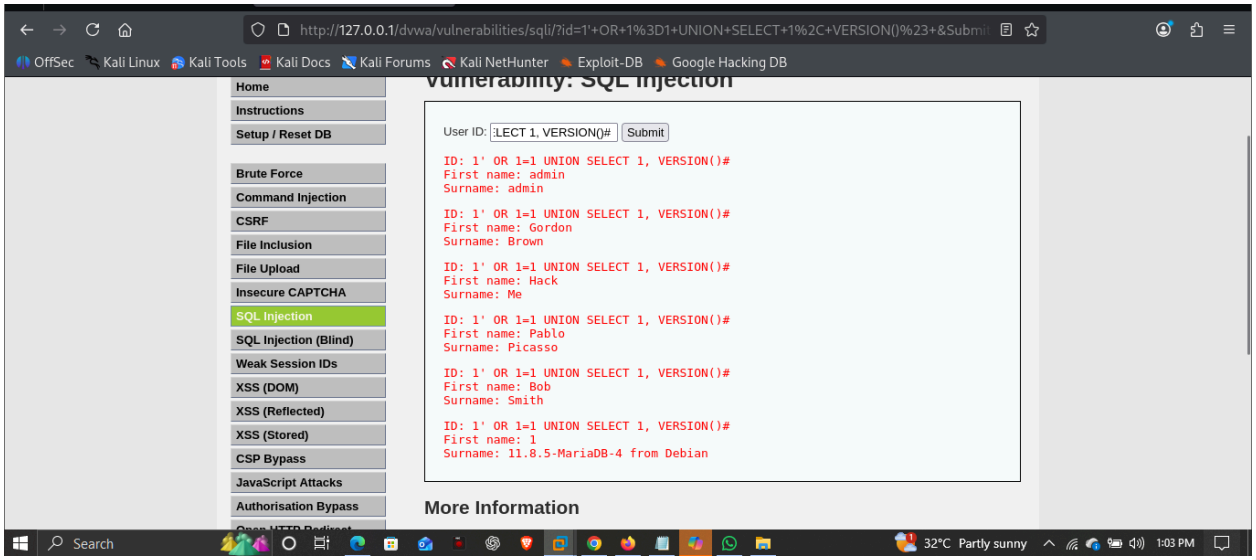


- In the User ID: field type 1' ORDER BY 3 # and click Submit.
- You should receive the following output, see screenshot below
- This time you should receive the error Unknown column '3' in 'order clause'. Because the third string returned an error, this tells us the query involves two fields. This is useful information to know as you continue your exploit.



Step 4: Check for version Database Management System (DBMS).

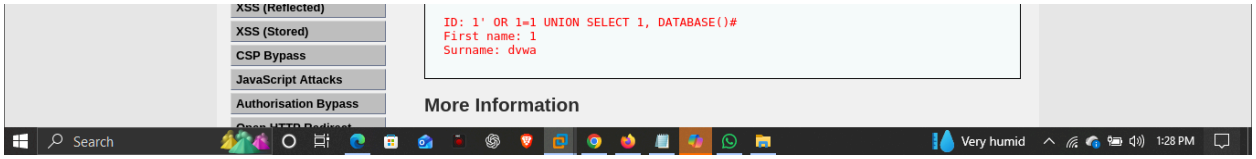
- In the User ID: field type 1' OR 1=1 UNION SELECT 1, VERSION()# and click Submit.
- At the end of the output, you should see a screenshot result similar to the following:



- The output 11.8.5 indicates the DBMS is MariaDB version 11.8.5 running on Debian.

Step 5: Determine the database name.

- So far you have learned that the database is vulnerable, the query involves two fields, and the DDMS is MariaDB 11.8.5
- Next, you will attempt to obtain more schema information about the database.
- In the User ID: field type 1' OR 1=1 UNION SELECT 1, DATABASE()# and click Submit.
- At the end of the output, you should see the following screenshot result:



- This means the name of the database is dvwa.

Conclusion

This project successfully demonstrated the exploitation of SQL injection vulnerabilities using DVWA as a controlled environment. Through systematic testing, it was shown that improperly sanitized user inputs can allow attackers to manipulate backend SQL queries, leading to unauthorized data access and potential system compromise.

The findings highlight the critical importance of secure coding practices. SQL injection remains one of the most prevalent web application vulnerabilities, despite being well-documented for over two decades. Organizations must adopt defensive measures such as parameterized queries, stored procedures, rigorous input validation, and regular vulnerability assessments.